

Инъекция кода

Описание проблемы

Использование потенциально опасных конструкций в коде позволяет выполнить произвольный код.

Пример 1.

Пусть есть метод `foo`, который принимает параметр `bar` типа `str`:

```
1 def foo(bar: str)
2     ...
3     s = eval(bar)
4     ...
```

Метод в какой-то момент применяет потенциально опасную функцию `eval` к переданной строке `bar`. В данном случае уязвимость налицо. При передаче корректного python-выражения в качестве значения `bar` в переменную `s` будет помещен результат этого выражения. Таким образом возможно манипулирование этой переменной, которая может использоваться в коде.

А можно, наоборот, спровоцировать ошибку, текст которой будет содержать интересующую информацию. Например, следующим образом:

```
>>> bar = "{}[open('/etc/passwd').read()]"
>>> eval(bar)
Traceback (most recent call last):
  File "<stdin>", line 1, in <module>
  File "<string>", line 1, in <module>
KeyError: 'root:x:0:0:root:/root:/bin/bash\ndaemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin\man:x:6:12:man:/var/cache/man:/usr/sbin/nologin\nlp:x:7:'
```

Воспользовавшись сетевым сниффером, можно увидеть интересующую информацию.

Пример 2.

```
16 def get_rs( ДопПоля, Филтр, Сортировка, Навигация ):
17     if 'ОригиналОбъекта' in Филтр and 'ОригиналМетода' in Филтр:
18         obj = getattr( sbis, str( Филтр.ОригиналОбъекта ) )
19         if obj:
20             method = getattr( obj, str( Филтр.ОригиналМетода ) )
21             return method( ДопПоля, Филтр, Сортировка, Навигация )
22     else:
```

Другим небезопасным примером может послужить передача атрибутов и методов с клиента. В примере выше происходит вызов указанного в параметрах метода БЛ, что позволяет злоумышленнику вызвать любой списочный метод в обход системы прав.

Результат эксплуатации

Выполнение произвольного кода на серверах компании.

Как исправить?

Крайне не рекомендуется использовать потенциально опасные функции и модули!

- Для Python: `eval`, `exec`, `input`, `subprocess`, `os.system`, `os.popen`, `os.spawn`, `pickle`, `cPickle`, `pty`, `stdout`, `cmd`, `pyexec`, `pyexpect`, `commands`, `sh`, `fabric`;
- Для C/C++: `system`, `exec`, `ShellExecute`, `ShellExecuteEx`, `redis::Client -> Eval`;
- NodeJS: `eval`;
- Java: `Runtime.exec()`.

Если их использование исключить невозможно, то нужно тщательно проверять пользовательский ввод.

